

İŞLETİM SİSTEMİ GÜVENLİĞİ

[Kaynak](#)

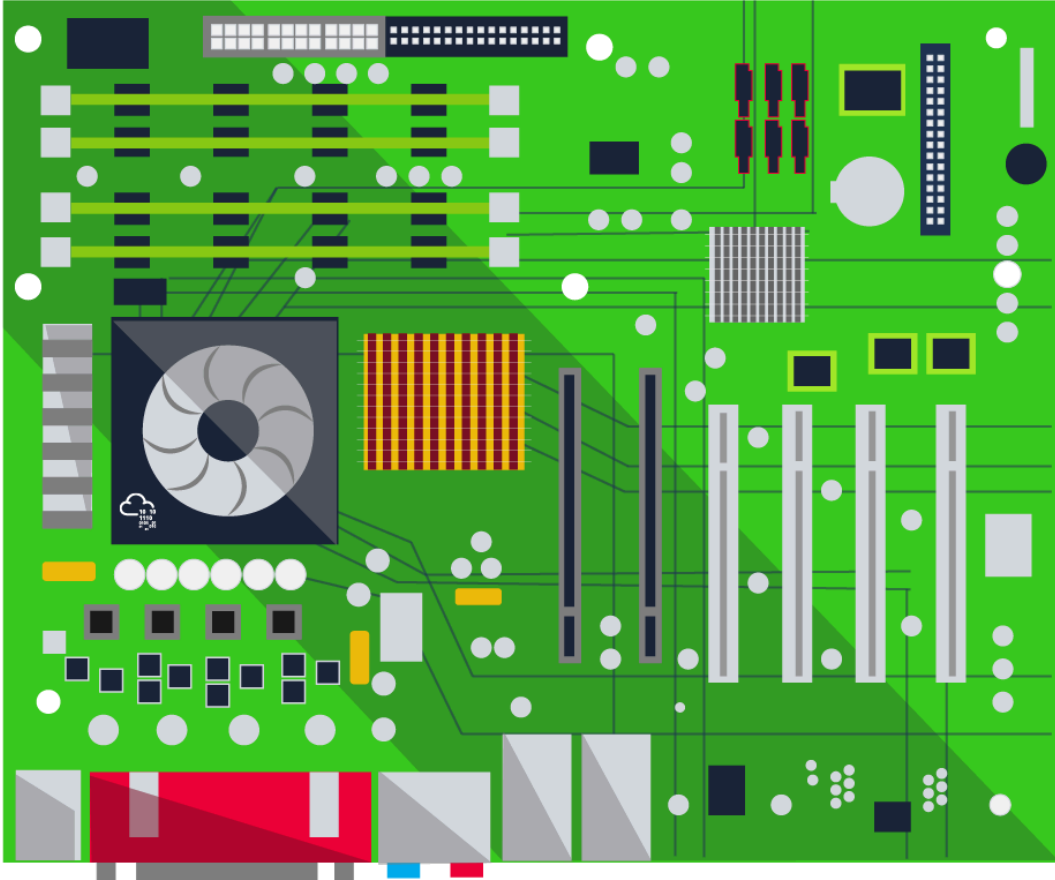
İÇERİK

1. İşletim Sistemi Güvenliğine Giriş (Introduction to Operating System Security)
2. İşletim Sistemi Güvenliğinde Sık Karşılaşılan Zafiyetler (Common Examples of OS Security)
3. İşletim Sistemi Güvenliği Uygulamalı Senaryosu

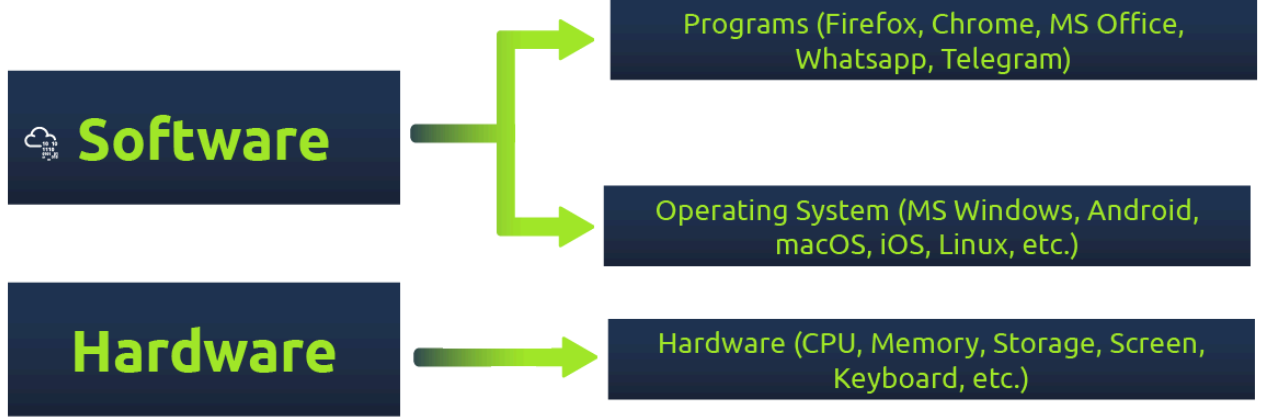
İşletim Sistemi Güvenliğine Giriş (Introduction to Operating System Security)

Donanım ve Yazılım Arasındaki İletişim Mimarisi

Bilişim sistemleri en temel düzeyde, fiziksel bileşenlerden oluşan donanım (hardware) katmanı üzerine inşa edilir. Siber güvenlik perspektifinden, bir sistemin zafiyetlerini analiz etmeden önce mimariyi kavramak zorunludur. İşlem süreçlerini yürüten **CPU** (Central Processing Unit), geçici ve hızlı veri erişimi sağlayan **RAM** (Random Access Memory) ve kalıcı veriyi tutan depolama birimleri (**HDD** veya **SSD**) doğrudan anakart (desktop board) üzerinde entegre çalışır.



Ancak fiziksel donanım, üzerinde çalışacak bir denetim mekanizması olmadan izole ve işlevsizdir. Bu noktada İşletim Sistemi (**OS - Operating System**), donanım ile son kullanıcı uygulamaları (Firefox, WhatsApp vb.) arasına konumlanan hayati bir köprü (abstraction layer) görevi görür. Uygulamalar doğrudan donanımla konuşamaz; işletim sisteminin belirlediği katı kurallar ve bellek yönetim (memory management) prensipleri üzerinden donanıma erişim talep ederler. Bir saldırganın işletim sistemi seviyesinde **Privilege Escalation** (Yetki Yükseltme - Düşük yetkili bir hesabın, sistem üzerinde daha yüksek veya root/administrator seviyesinde haklar elde etmesi süreci) yapmaya çalışmasının temel nedeni de budur: OS'i kontrol eden, donanımı ve tüm uygulamaları kontrol eder.

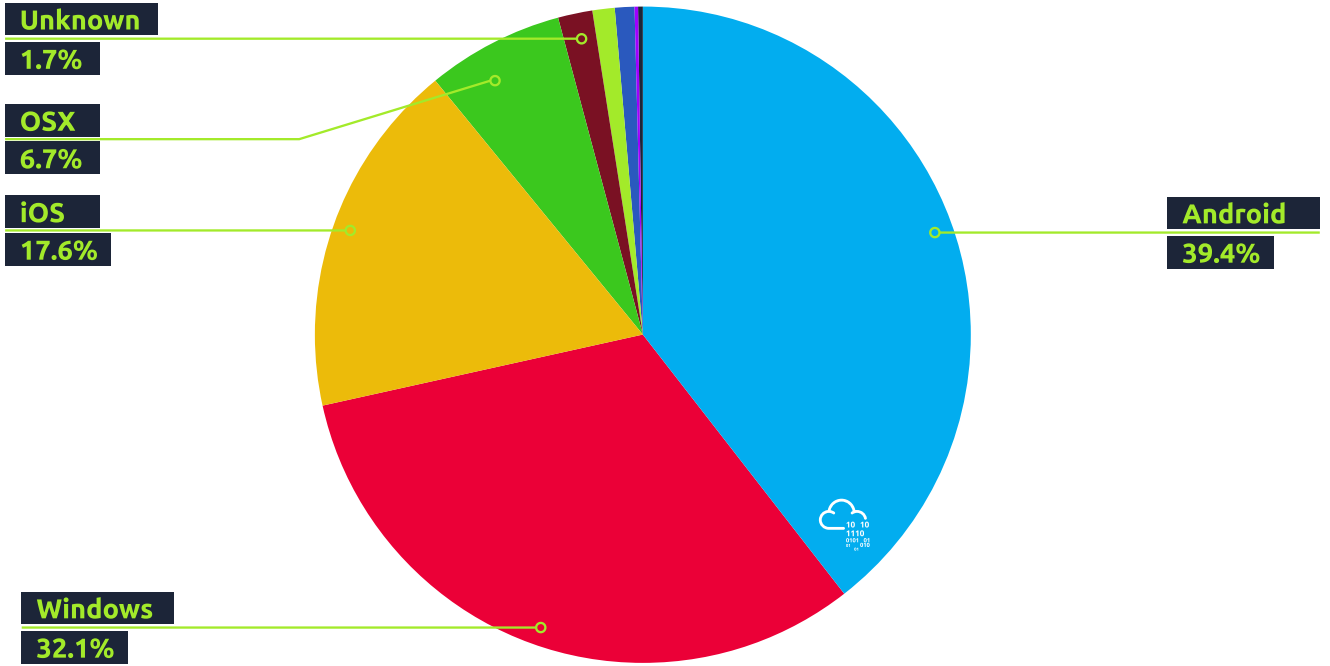


Yukarıdaki mantıksal mimari, bir uygulamanın donanıma ulaşmak için işletim sisteminden geçmek zorunda olduğunu gösterir. Siber güvenlikte temel amaç, genellikle bu ara katmandaki (OS) mantıksal hataları veya yetkilendirme boşluklarını sömürmek veya savunmaktır.

İşletim Sistemi Sınıflandırmaları ve Hedef Yüzeyleri (Attack Surfaces)

İşletim sistemleri, kullanım senaryolarına ve hizmet ettikleri cihaz mimarisine göre sınıflandırılır. Her bir sınıf, ağ üzerinde farklı bir hedef yüzeyi oluşturur:

Operating System Market Share Worldwide (Jan 2022)



- **Kişisel Bilgisayarlar (Client/Desktop OS):** MS Windows 11 ve macOS gibi sistemler. Son kullanıcının günlük işleri için tasarlandığından, genellikle ortalama (phishing) veya zararlı yazılım (malware) saldırılarının birincil hedefidir.
- **Mobil Sistemler (Mobile OS):** Android ve iOS. Modern dönemde en kritik kişisel verileri (fotoğraflar, şifreler, e-bankacılık verileri) taşıdıkları için mobil güvenlik başlı başına izole bir disiplindir.
- **Sunucu Sistemleri (Server OS):** MS Windows Server 2022, IBM AIX ve Oracle Solaris. Ağ üzerinde kritik servisleri (web, veritabanı, dosya paylaşımı) barındırdıkları için kurumsal ağ sızma testlerinde (penetration testing) ele geçirilmesi hedeflenen en yüksek değere sahip sistemlerdir.
- **Hibrit ve Geniş Kapsamlı Sistemler:** Linux. Hem kişisel bilgisayarlarda hem de dünya çapındaki web sunucularının büyük çoğunluğunda çalışacak kadar esnektir.

Bilgi Güvenliğinin Temel Taşları: CIA Üçlüsü (CIA Triad)

Gerek kişisel bir mobil cihazda saklanan kimlik kopyaları/şifreler, gerekse bir sunucudaki kurumsal veri tabanları olsun, sistemde barındırılan verinin kritikliği **OS** güvenliğini zorunlu kılar. İşletim sistemi güvenliği, üç ana sütun üzerine inşa edilir. Kapsamlı bir siber saldırının temel amacı, bu sütunlardan en az birini yıkmaktır.

DİKKAT: Sınavlarda, raporlarda veya mülakatlarda bir zafiyetin etkisini açıklarken, sistemdeki hangi güvenlik sütununun ihlal edildiğini net olarak belirtmek teknik analizin temel şartıdır.



1. **Confidentiality (Gizlilik):** Sistemdeki özel dosyaların, iletişim loglarının ve şifrelerin yalnızca yetkilendirilmiş kişiler veya süreçler (processes) tarafından okunabilmesidir. *İhlali durumunda:* Yetkisiz bir saldırgan cihazdaki hassas verilere erişir. Bu durum doğrudan Veri Sızıntısı (Data Breach) olarak adlandırılır.
2. **Integrity (Bütünlük):** Verinin sistemde depolanırken veya ağ üzerinde iletilirken (in-transit) yetkisiz kişiler tarafından değiştirilmemesi (tampering) ve orijinalliğinin korunmasıdır. *İhlali durumunda:* Veri manipüle edilir. Örneğin bir log dosyası, saldırganın izlerini silmek amacıyla değiştirildiğinde sistemin bütünlüğü bozulmuş olur.
3. **Availability (Erişilebilirlik):** Sistemin, donanımın veya verinin yetkili kullanıcılar tarafından ihtiyaç duyulduğu her an erişilebilir ve kullanılabilir durumda olmasıdır. *İhlali durumunda:* Cihaz çökertilir veya kaynakları tüketilir (Örn: Denial of Service - DoS saldırıları). Alternatif olarak Fidyeye Yazılımı (Ransomware) ile dosyalar şifrelenerek sistem kilitlenir ve kullanıcının veriye erişimi engellenir.

ÖNEMLİ: Tüm işletim sistemlerinde savunma (Blue Team) veya saldırı (Red Team) stratejileri kurgulanırken, daima bu üç parametrenin (Confidentiality, Integrity, Availability) hangi noktada risk altında olduğu analiz edilmelidir. Sonraki teknik aşamalarda karşılaşılan her saldırı vektörü, bu üç temel kuraldan birini yıkmak üzerine tasarlanmış olacaktır.

İşletim Sistemi Güvenliğinde Sık Karşılaşılan Zafiyetler (Common Examples of OS Security)

Bir işletim sisteminin mimari güvenliği, barındırdığı verinin ve sunduğu servislerin kritikliği ile doğrudan orantılıdır. Daha önceki aşamalarda temel çerçevesi çizilen **CIA Üçlüsü**

(**Confidentiality** - Gizlilik, **Integrity** - Bütünlük, **Availability** - Erişilebilirlik), siber saldırganların ana hedef noktasıdır. Sistem mimarisinde bu üç temel güvenlik sütununu yıkmak amacıyla genellikle üç ana zafiyet vektörü istismar edilir: Kimlik doğrulama mekanizmalarındaki zayıflıklar, hatalı yapılandırılmış dosya izinleri ve sisteme sızan zararlı yazılımlar.

Kimlik Doğrulama (Authentication) ve Zayıf Parola Zafiyetleri

Authentication (Kimlik Doğrulama), bir sisteme (lokal veya uzak bir sunucuya) erişim talep eden kullanıcının, iddia ettiği kişi olup olmadığını kriptografik veya mantıksal olarak kanıtlama sürecidir. Geleneksel ve modern sistemlerde kimlik doğrulama mimarisi üç temel faktör (factor) üzerine inşa edilir:

1. **Something you know (Bilddiğiniz bir şey):** Parolalar (Password), PIN kodları veya gizli sorular. Sistemin hafızasındaki hash (kriptografik özet) değeri ile kullanıcının girdiği bilginin eşleşmesine dayanır.
2. **Something you are (Olduğunuz bir şey):** Biyometrik veriler. Parmak izi, retina taraması veya yüz tanıma algoritmaları. (Fiziksel değişmezlik ilkesine dayanır).
3. **Something you have (Sahip olduğunuz bir şey):** Akıllı kartlar (Smart cards), donanımsal token'lar (YubiKey) veya SMS/Authenticator uygulamaları üzerinden gelen Tek Kullanımlık Şifreler (**OTP** - One Time Password).

Parolalar, yapılandırılması ve dağıtımı en kolay yöntem olduğu için günümüzde hala en yaygın **Authentication** faktörüdür. Ancak insan faktörünün (human element) devreye girmesi, parolaları sistemin en zayıf halkası haline getirir. Kullanıcıların karmaşık şifreleri hatırlamakta zorlanması, evcil hayvan isimleri veya doğum tarihleri gibi **OSINT** (Açık Kaynak İstihbaratı) yöntemleriyle kolayca elde edilebilecek verileri kullanmalarına yol açar. Saldırganlar, kaba kuvvet (**Brute-Force**) ve sözlük (**Dictionary**) saldırılarını bu davranışsal zafiyetleri sömürmek üzerine optimize ederler.

Aşağıda, NCSC (National Cyber Security Centre) tarafından yayınlanan ve dünya çapında en sık kullanılan 20 parolanın analizini içeren bir tablo / wordlist (kelime listesi) örneği bulunmaktadır:

```
# NCSC Top 20 Common Passwords List (Snippet)
123456
123456789
qwerty
password
111111
12345678
abc123
1234567
password1
1012345
111234567890
```

12123123
13000000
14iloveyou
151234
161q2w3e4r5t
17qwertyuiop
18123
19monkey
20dragon

Çıktı / Hedef Yüzeyi Analizi: Bu listedeki parolalar incelendiğinde, saldırganların **Dictionary Attack** (sözlük saldırısı) araçlarında neden özel kurallar (rulesets) kullandığı net bir şekilde görülür:

- 123456 , 111111 gibi dizilimler tamamen sayısal ardışıklığa dayanır.
- password , iloveyou , monkey , dragon gibi kelimeler doğrudan sözlükte bulunan (dictionary words) ve kırma (cracking) araçlarının ilk saniyede denediği varyasyonlardır.
- **ÖNEMLİ:** Listede yer alan qwerty , qwertyuiop ve 1q2w3e4r5t gibi kombinasyonlar sözlükte bulunmasa da yüksek risk taşır. Bunlar **Keyboard Walk** (Klavye yürüyüşü) veya **Pattern** (Desen) olarak adlandırılır. Bir parola kırma aracı (Örn: Hashcat veya John the Ripper), standart bir sözlük taramasından sonra doğrudan klavye üzerindeki bitişik tuş kombinasyonlarını dener. Kullanıcılar klavye dizilimine güvenerek karmaşık bir şifre yarattıklarını sanırlar, ancak bu kriptografik açıdan son derece öngörülebilir bir davranıştır.

Bu zafiyetin sistem üzerindeki nihai etkisi: Eğer bir saldırgan e-posta veya sosyal medya gibi bir hesabın parolasını tahmin edebilirse, ağ içerisine sızmak için gerekli olan ilk erişimi (**Initial Access**) sağlamış olur. Bu noktada **Confidentiality** (Gizlilik) tamamen çöker. Savunma stratejisi, mutlaka farklı platformlar için benzersiz (unique) parolalar kullanmayı ve **MFA** (Multi-Factor Authentication - Çok Faktörlü Kimlik Doğrulama) mimarisini zorunlu kılar.

Zayıf Dosya İzinleri (Weak File Permissions) ve En Az Yetki Prensibi

Kurumsal ağlarda veya yerel işletim sistemlerinde güvenliğin temeli **Principle of Least Privilege - PoLP** (En Az Yetki Prensibi) konseptine dayanır. Sistemdeki bir kullanıcının, servis hesabının (service account) veya bir programın, yalnızca görevini yerine getirebilmesi için ihtiyaç duyduğu asgari (minimum) erişim haklarına sahip olması gerekir.

Dosya izinlerinin (örneğin Linux sistemlerdeki okuma `r` , yazma `w` , çalıştırma `x` bitleri) hatalı yapılandırılması, siber saldırganlar için en önemli **Privilege Escalation** (Yetki Yükseltme) vektörlerinden biridir. Zayıf dosya izinleri sistemdeki iki ana güvenlik sütununu doğrudan hedef alır:

1. **Confidentiality (Gizlilik) İhlali:** Normal şartlarda sadece kök kullanıcının (root/administrator) okuyabileceği kritik konfigürasyon dosyaları, veritabanı bağlantı

dizesi (connection string) içeren yedekler veya şifre hashlerini barındıran dosyalar (Örn: /etc/shadow), zayıf okuma izinleri (world-readable) nedeniyle düşük yetkili bir saldırgan tarafından okunabilir.

2. **Integrity (Bütünlük) İhlali:** Eğer kritik bir sistem dosyası, script veya zamanlanmış görev dosyası (cron job) tüm kullanıcılar tarafından yazılabilir (world-writable) şekilde bırakılmışsa, saldırgan bu dosyanın içeriğini zararlı bir **Payload** (saldırı kodu) ile değiştirebilir. Bu durum, dosyayı sistem veya yüksek yetkili bir kullanıcı çalıştırdığında bütünlüğün bozulmasına ve saldırganın sistemi tamamen ele geçirmesine yol açar.

Zararlı Yazılımlar (Malicious Programs) ve Sisteme Etkileri

İşletim sistemi güvenliğinde üçüncü büyük risk, kullanıcı etkileşimiyle veya ağ zafiyetleri (vulnerabilities) kullanılarak sisteme enjekte edilen zararlı yazılımlardır. Zararlı yazılımın (Malware) türü, **CIA** üçlüsünün hangi bacağının hedef alındığını belirler:

- **Trojan Horses (Truva Atları) ve Gizlilik/Bütünlük Hedefi:** Trojan'lar, meşru ve faydalı bir yazılım gibi görünen ancak arka planda gizlice çalışan zararlı programlardır. Bir sisteme Trojan bulaştığında, saldırgan genellikle bir **Reverse Shell** (Sistemin, saldırganın sunucusuna bağlandığı komut satırı bağlantısı) veya arka kapı (backdoor) elde eder. Bu erişim, saldırganın sistemdeki dosyaları okumasını (**Confidentiality** ihlali) ve dosyaları gizlice değiştirmesini/veritabanlarını manipüle etmesini (**Integrity** ihlali) sağlar.



- **Ransomware (Fidye Yazılımı) ve Erişilebilirlik Hedefi:** Ransomware, doğrudan **Availability** (Erişilebilirlik) kuralını yıkan spesifik bir zararlı yazılım türüdür. Sisteme sızdığında, kurbanın diskinde bulunan belgeleri, veritabanlarını ve medyaları asimetrik veya simetrik güçlü kriptografik algoritmalarla (Örn: AES/RSA) şifreler (**Encryption**).

Şifreleme işlemi, doğru anahtar (decryption key) olmadan veriyi tamamen anlamsız bir veri yığınına (gibberish) dönüştürür. Saldırgan, dosyaları eski orijinal haline döndürecek (**Decryption** - şifre çözme) anahtarını vermek karşılığında fidye talep ederek, sistemin erişilebilirliğini bir şantaj aracına çevirir.

DİKKAT: Başarılı bir Ransomware saldırısında sistem tamamen çalışıyor gibi görünse de, iş süreçleri için kritik olan veriye ulaşılamaması, sistemin **Availability** açısından tam anlamıyla çökertildiği anlamına gelir. Bu nedenle işletim sistemi güvenliğinde sadece dışarıdan gelen bağlantıları engellemek (Firewall) yetmez, dosya bütünlüğünü izleyen (FIM) ve fidye yazılımı davranışlarını heuristik olarak tespit eden EDR (Endpoint Detection and Response) sistemlerine ihtiyaç vardır.

İşletim Sistemi Güvenliği Uygulamalı Senaryosu

Siber saldırılarda bir hedefe yönelik en yaygın yaklaşım, uzaktaki sisteme yetkisiz erişim sağlamaktır. Bu durum genellikle hedefi zararlı bir dosya çalıştırmaya ikna ederek veya geçerli bir kullanıcı adı ve parola kombinasyonunu ele geçirerek (**Credential Compromise**) gerçekleştirilir. Hedef sistem üzerinde bir kullanıcının kimlik bilgileriyle **Initial Access** (İlk Erişim - Sisteme dışarıdan ilk girişin sağlanması) elde edildikten sonra, saldırırganın nihai amacı **Privilege Escalation** (Yetki Yükseltme - Düşük yetkili bir hesaptan sistem yöneticisi haklarına geçiş) yapmaktır.



Tam yetkili bu yönetici hesabı Linux, macOS ve Android sistemlerinde **root**, MS Windows sistemlerinde ise **administrator** olarak adlandırılır. Bu hesaplar, işletim sistemi üzerinde hiçbir kısıtlama olmaksızın tüm dosyalara, servislere ve donanıma müdahale etme yetkisine sahiptir.

Kimlik Bilgilerinin İstismarı ve Güvenli Kabuk (SSH) Bağlantısı

Senaryomuzda, yapılan fiziksel bir keşif (Physical Reconnaissance) sırasında hedefin ofisinde monitör üzerinde unutulmuş bir yapışkan notta **sammie** ve **dragon** kelimeleri tespit edilmiştir. Bu bilgilerin **MACHINE_IP** adresindeki hedef sistemin kullanıcı adı ve parolası olduğu varsayımıyla sisteme uzaktan bağlanmayı deneyeceğiz.

Linux sistemlerde uzaktan komut çalıştırmak ve sistemi yönetmek için kullanılan en yaygın protokol SSH'tır (Secure Shell - Kriptografik ağ protokolü). Hedefe bağlanmak için aşağıdaki komut sözdizimini (syntax) kullanıyoruz:

```
ssh sammie@MACHINE_IP
```

Bu komutta `ssh` çalıştırılacak aracı, **sammie** bağlanmak istediğimiz hedef kullanıcıyı, `@` işareti ayracı, **MACHINE_IP** ise hedefin ağdaki konumunu belirtir.

Bağlantıyı başlattığımızda karşılaşacağımız terminal çıktısı ve bu çıktının teknik analizi aşağıdadır:

```
user@AttackBox# ssh sammie@MACHINE_IP
The authenticity of host 'MACHINE_IP (MACHINE_IP)' can't be established.
ECDSA key fingerprint is SHA256:IFP+sTfHTDm72Ta2zfK9XjKASr30+ya4ic/ApEIziio.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added 'MACHINE_IP' (ECDSA) to the list of known hosts.
sammie@MACHINE_IP's password:
Welcome to Ubuntu 20.04.4 LTS (GNU/Linux 5.4.0-100-generic x86_64)

[...]
System information as of Tue  1 Mar 13:20:32 UTC 2022
System load:  0.03                Processes:            216
Usage of /:   51.8% of 6.53GB      Users logged in:     1
Memory usage: 17%                 IPv4 address for ens33: MACHINE_IP
Swap usage:   0%

Last login: Tue Mar  1 09:46:11 2022 from MACHINE_IP
```

Çıktı Analizi ve Mantıksal Arka Plan:

- The authenticity of host...** : SSH protokolü "Trust on First Use" (İlk Kullanımda Güven) prensibiyle çalışır. Hedef sunucuya ilk defa bağlandığınızda, sunucu size kimliğini kanıtlamak için bir ECDSA (Elliptic Curve Digital Signature Algorithm) parmak izi sunar. Bunu onaylayıp `yes` yazdığınızda, bu imza yerel makinenizdeki `~/.ssh/known_hosts` dosyasına kaydedilir. Bu mekanizma, gelecekte yapılabilecek Oltadaki Adam (**Man-in-the-Middle - MitM**) saldırılarını tespit etmek için kritiktir.
- sammie@MACHINE_IP's password:** Parolayı (**dragon**) girerken terminalde yıldız (`*`) veya nokta gibi hiçbir karakter görünmez. Bu, omuz sörfü (shoulder surfing) gibi fiziksel

izleme saldırılarını engellemek için Unix/Linux sistemlerinin standart bir güvenlik davranışıdır; sistem aslında tuş vuruşlarınızı okumaktadır.

- **Welcome to Ubuntu 20.04.4 LTS:** Sisteme başarılı bir şekilde giriş yaptığımızda bizi karşılayan MOTD (Message of the Day) ekranıdır. İşletim sisteminin sürümünü, çekirdek (kernel) versiyonunu, anlık donanım yükünü ve ağ arayüzündeki (ens33) IP adresini sızdırır. Bir saldırgan için bu bilgiler, sisteme özel (Örneğin Linux Kernel 5.4.0 zafiyetleri) yerel yetki yükseltme (**Local Privilege Escalation**) exploitlerini seçmek için paha biçilemez bir başlangıç noktasıdır.

Sistem İçi Keşif (Local Enumeration)

Başarılı bir **Initial Access** sonrası atılması gereken ilk adım, sistemdeki mevcut konumu ve erişilebilen verileri anlamaktır (**Enumeration** - Sistem hakkında detaylı bilgi toplama aşaması).

```
sammie@beginner-os-security:~$ whoami
sammie
sammie@beginner-os-security:~$ ls
country.txt  draft.md  icon.png  password.txt  profile.jpg
sammie@beginner-os-security:~$ cat draft.md
# Operating System Security
Reusing passwords means that your password for other sites becomes exposed
if one service is hacked.
sammie@beginner-os-security:~$
```

Komutların ve Çıktıların Analizi:

- **whoami** : Terminal oturumunun hangi kullanıcı haklarıyla çalıştığını (UID/GID bağlamını) doğrulamak için kullanılır. Çıktının **sammie** olması, henüz düşük yetkili bir kullanıcı olduğumuzu doğrular.
- **ls** : (List). Bulduğumuz dizindeki dosya ve klasörleri listeler. Zafiyet ararken burada gizli dosyaları (başında nokta olan, örn. **.ssh** veya **.bashrc**) görmek için genellikle **ls -a** veya detaylı listeleme için **ls -la** parametreleri tercih edilir.
- **cat draft.md** : **cat** (Concatenate), bir dosyanın içeriğini okumak ve standart çıktıya (terminal ekranına) yazdırmak için kullanılır. Hedef sistemde bulduğumuz **draft.md** dosyasını okuduğumuzda, ironik bir şekilde parolaların tekrar kullanılmaması gerektiğine dair bir güvenlik notuyla karşılaşırız. Bir sızma testinde, **cat** ile okunacak asıl hedefler **password.txt** gibi bariz isimli dosyalar veya yapılandırma dosyalarıdır.

Bu aşamada çalıştırılabilecek en kritik komutlardan bir diğeri **history** komutudur.

ÖNEMLİ: **history** komutu, kullanıcının o terminalde daha önce çalıştırdığı komutların bir listesini tutan **.bash_history** (veya benzeri) dosyasının içeriğini ekrana basar. Bir saldırgan veya Red Team uzmanı, sisteme sızdığında ilk olarak komut geçmişine bakar; çünkü

dikkatsiz sistem yöneticileri veritabanı bağlantı şifrelerini, SSH anahtarlarını veya API token'larını komut satırına doğrudan (**plain-text**) parametre olarak yazmış olabilirler.

Yatay Hareket (Lateral Movement) ve Alternatif Kullanıcı Tespiti

Elde edilen veriler doğrultusunda sistemde siber güvenlik pratiklerini önemsemeyen iki farklı kullanıcı daha tespit edilmiştir: **johnny** ve **linda**. Amacımız yetkilerimizi artırmak olduğu için mevcut **sammie** kullanıcısından bu hesaplara geçiş yapmak, yani **Lateral Movement** (Yatay Hareket - Aynı yetki seviyesindeki sistemler veya kullanıcılar arasında ilerleme) gerçekleştirmek istiyoruz. Bu iki zayıf profilli kullanıcının parolalarını tahmin etmek (Guessing/Brute-forcing) için iki farklı metodoloji izleyebiliriz:

Yöntem 1: Dışarıdan Doğrudan SSH Erişimi Eğer hedef sisteme yerelden (**sammie** üzerinden) değil de, dış ağdan doğrudan saldırmak istersek, yeni hedeflerimiz için SSH servisini kullanabiliriz:

```
ssh johnny@MACHINE_IP
```

Bu yöntem, kullanıcının parolalarını dışarıdan manuel olarak veya otomatize edilmiş araçlarla (örn. Hydra, Medusa) denemek için uygundur.

Yöntem 2: Sistem İçerisinden Kullanıcı Değiştirme (Switch User) Halihazırda **sammie** kullanıcısı ile sistemin içine sızmış durumdaysak, dışarı çıkmadan doğrudan işletim sisteminin kendi aracı olan **su** (Substitute User) komutunu kullanarak hedef kullanıcının kimliğine bürünmeye çalışabiliriz:

```
su - johnny
```

DİKKAT: Burada kullanılan **-** (tire) parametresi son derece kritiktir. **su johnny** komutu sadece kullanıcı haklarını değiştirirken, **su - johnny** komutu (Login Shell) **johnny** kullanıcısının tüm çevresel değişkenlerini (environment variables, PATH ayarları, home dizini konfigürasyonları) yükleyerek gerçek bir giriş simülasyonu yaratır. Sistem sizden **johnny**'nin parolasını isteyecektir; parola tahmini başarılı olursa oturumunuz **sammie**'den **johnny**'ye yükselecektir/gececektir.